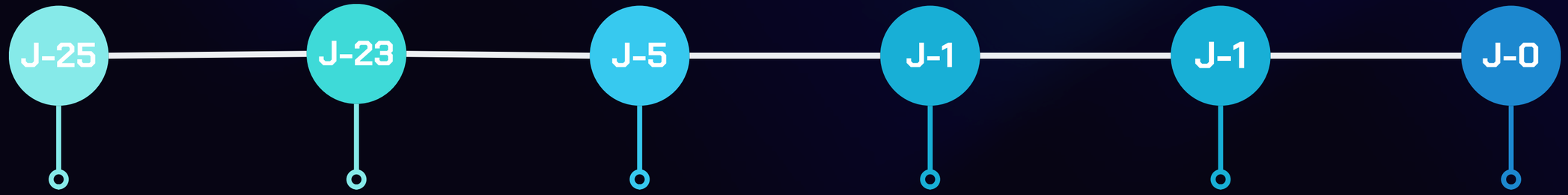
BuildSec
EPITA Rennes

EPITA

LiteLLM Supply Chain Attack

L'Intrus Invisible : Comment LiteLLM a été détourné

La Chaîne d'Attaque



February 27
Exploitation de la CI de Trivy

March 1
Rotation incomplète des tokens

March 19
Trivy 0.69.4

March 23 14:31
Vol du token PYPI_PUBLISH

March 23 21:28
litellm.cloud enregistré

March 24 14:31
LiteLLM 1.82.7

Enzo Juhel

Source : ramimac.me/teampcp/

BuildSec
EPITA Rennes

EPITA

LiteLLM Supply Chain Attack

L'Intrus Invisible : Comment LiteLLM a été détourné

La Chaîne d'Attaque

March 24



10:52
LiteLLM 1.82.8

11:48
Découverte du malware

12:44
Spam sur l'Issue GitHub

12:58
Repos GitHub vandalisés

14:00
Mise en quarantaine sur PyPI

15:35
PYSEC-2026-2

Source : ramimac.me/teampcp/

Enzo Juhel

BuildSec
EPITA Rennes

EPITA

LiteLLM Supply Chain Attack

Compromission Totale : L'Onde de Choc

Ce qui est arrivé aux victimes



Vol de Tokens/Identifiants



Chiffrement



Exfiltration

Enzo Juhel

Source : Issue GitHub #24512 de LiteLLM

BuildSec
EPITA Rennes

Telnyx Attaque par la chaîne d'approvisionnement

SDK Telnyx PyPI compromis

Malware caché dans des fichiers audio WAV

TeamPCP Supply Chain Campaign — 27 mars 2026

670K+
Téléchargements / mois

3
Jours après LiteLLM

-87%
Empreinte vs LiteLLM

BuildSec
EPITA Rennes

EPITA

Telnyx Attaque par la chaîne d'approvisionnement

L'attaque

Trois jours après LiteLLM, TeamPCP frappe Telnyx avec une nouvelle technique

Comment

Token PyPI volé via LiteLLM

Le malware LiteLLM a aspiré les secrets des environnements de dev, dont le token de publication Telnyx. Pas de Trusted Publishers (OIDC) en place.

Injection dans le SDK légitime

Le SDK fonctionne normalement mais le malware s'exécute en parallèle dès l'import. Rien de visible côté développeur.

Stéganographie WAV

Le vrai payload est caché dans les frames audio d'un fichier .wav valide. Passe les filtres réseau, proxies, antivirus.

Conséquences

Vol massif de secrets

SSH, credentials cloud AWS/GCP/Azure, tokens Kubernetes, wallets crypto, certificats TLS, fichiers .env, historiques shell.

Exploitation active du cloud

Le malware utilise les credentials AWS trouvés pour interroger Secrets Manager et SSM. Il ne se contente pas de vole, il exploite.

Persistance

Windows : Un executable dans le dossier Startup. Linux/macOS : services de persistance renommés pour éviter de possibles règles de détéction.

BuildSec
EPITA Rennes



Telnyx Attaque par la chaîne d'approvisionnement

Trois leçons

1 **Verrouiller les dépendances**

Un numéro de version ne garantit rien. Seul le hash du package prouve son intégrité. Même logique pour les GitHub Actions : épingler sur un hash de commit, pas un tag détournable.

2 **Abandonner les tokens statiques**

Le token volé a tout permis. Avec OIDC (Trusted Publishers), c'est le pipeline qui prouve son identité à PyPI à chaque publication. Aucun secret à stocker, rien à voler.

3 **Surveiller le comportement**

Un processus Python qui télécharge un .wav depuis une IP externe ? Signal d'alerte. La détection par type de fichier ne suffit plus : raisonner en comportement attendu vs observé.

BuildSec
EPITA Rennes

EPITA

Telnyx Attaque par la chaîne d'approvisionnement

Ce qu'il faut retenir

> TeamPCP enchaîne les compromissions en cascade, chaque package infecté donne les clés du suivant. Environ **300 Go de secrets compressés** revendus à des groups de ransomware.

Commission Européenne

Mercor

Source : Endor Labs — 27 mars 2026



BuildSec
EPITA Rennes

Merci pour votre écoute

Kylian Nézan & Enzo Juhel

Epita Rennes - Majeure BuildSec